Tekst prezentacji PPMGR

Przywitanie

Agenda

Protokół MCP

Protokół MCP jest standardem open-source, udostępnionym przez firmę Anthropic w listopadzie 2024 roku. Służy do poszerzania wiedzy LLMu oraz do jego integracji z zewnętrznymi narzędziami, pozwalającymi AI stać się aktywną częścią systemu. Motywacją do jego powstania było ustandaryzowanie tych integracji oraz zmniejszenie ich ilości. Gdy powstały pierwsze narzędzia rozszerzające możliwości LLM, konieczne było pisanie integracji między każdym modelem i każdym narzędziem, co daje M razy N intergracji. Wprowadzenie standardu MCP umożliwiło zmniejszenie integracji do M plus N.

OWASP

Wraz z rozwojem generatywnej sztucznej inteligencji i jej adopcji przez firmy, wzrosło zapotrzebowanie na identyfikację najpopularniejszych podatności i przede wszystkim sposobów im przeciwdziałania. Jedną z pierwszych inicjatyw było OWASP Top 10 for LLM Applications, rozpoczęta w maju 2023 roku. Z czasem projekt ewoluował w szerszy i bardziej ogólny OWASP GenAI Security Project. Jednym z podprojektów tej inicjatywy jest OWASP MCP Top 10, skoncentrowany wyłącznie na zagrożeniach związanych z protokołem MCP. Warte odnotowania jest, że na liście najpopularniejszych ataków na aplikacje wykorzystujące LLM z 2025 roku, ataki na warstwę MCP znajdują się na 3 miejscu. W tym momencie pierwsze wydanie listy top 10 dla MCP jest w fazie beta-testów, to znaczy została napisana pierwsza wersja tej listy i zbierane są opinie deweloperów na jej temat. Obecnie trzema najważniejszymi podatnościami są:

- błędne zarządzanie tokenami i wyciek sekretów
- zbyt szerokie uprawnienia narzędzi MCP
- zatruwanie narzędzi MCP

Badania

Ze względu na to, że protokół jest w powszechnym użyciu niecałe 2 lata, badania bezpieczeństwa są w bardzo wczesnym stadium. Artykuły naukowe napisane cztery miesiące po udostępnieniu samej technologii, dopiero dzisiaj są akceptowane i publikowane przez renomowane czasopisma. Znalezione przeze mnie prace pochodzą w zdecydowanej większości z Chin. Skupiają się głównie albo na opisywaniu samego protokołu, z identyfikacją potencjalnych zagrożeń, albo są to badania odporności na ataki popularnych, ogólnodostępnych narzędzi MCP.
Na podstawie analizy sytuacji MCP na rynku, sformułowałem dwa potencjalne kierunki badawcze. Pierwszym z nich byłoby zbadanie skuteczności sugerowanych mechanizmów obronnych przed atakami na warstwę MCP. Wspomniane wcześniej prace czasami zawierają sugestie obrony przed atakami, ale

brakuje systematycznego badania ich skuteczności. Drugim kierunkiem byłoby trochę bardziej niszowe, ale zbadanie wpływu jakości opisów narzędzi MCP na decyzję agenta. Sprawdzone zostałoby, czy agent AI potrafi np. wykryć prompt injection w opisie narzędzia, albo czy opis w stylu "najlepsze na świecie narzędzie" skusiłoby agenta do jego użycia.